Standard Operating Procedure (SOP) for Risk Management

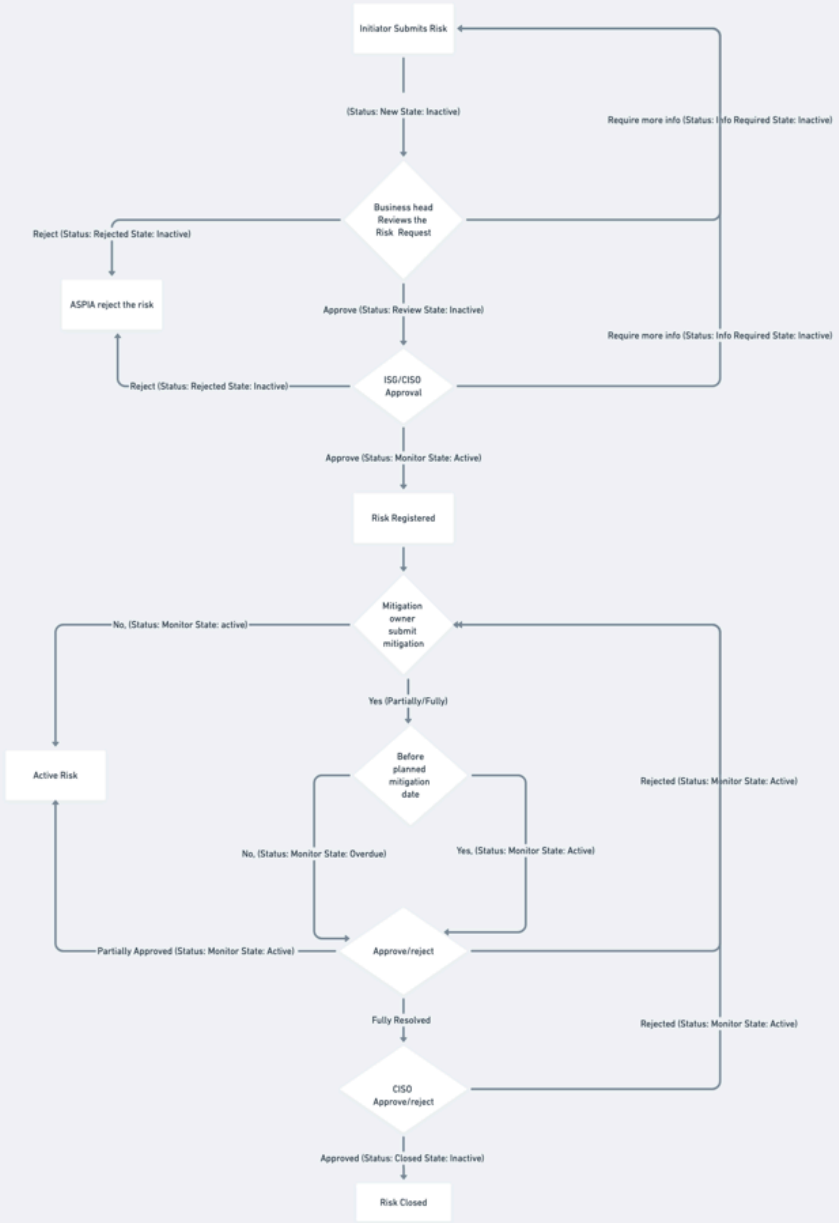
Objective

This SOP outlines the steps and procedures for managing risk requests within the ASPIA platform. The goal is to ensure that risks are handled efficiently, with proper approvals, and that the entire process is tracked and documented.

Scope

This procedure applies to all users involved in the submission, review, and approval of risk requests in the ASPIA platform.

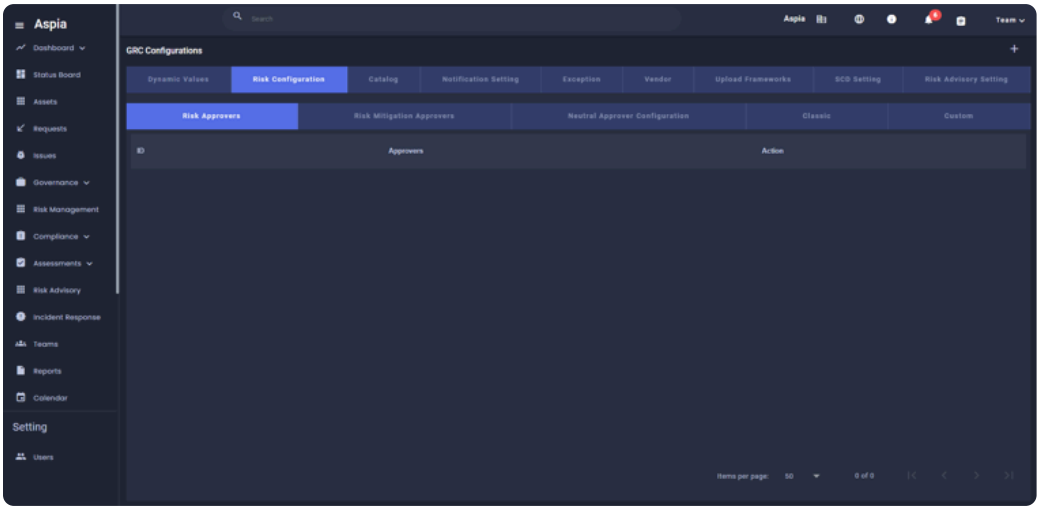
Flow Chart



Made with Whimsical

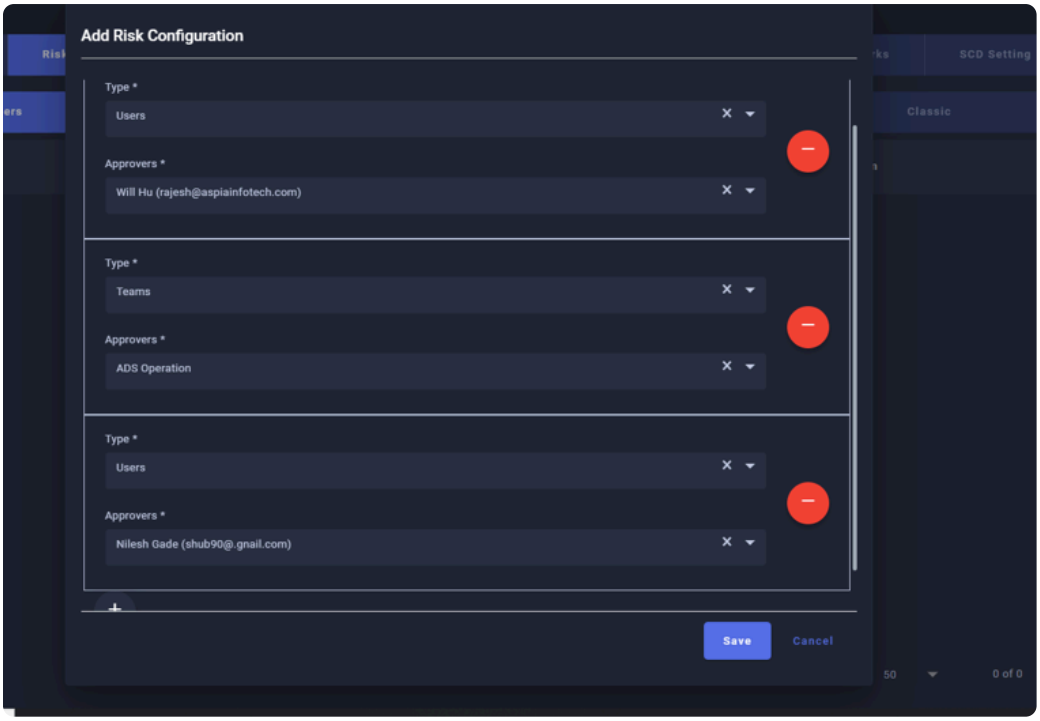
Risk Configurations

Approvers Configurations :-



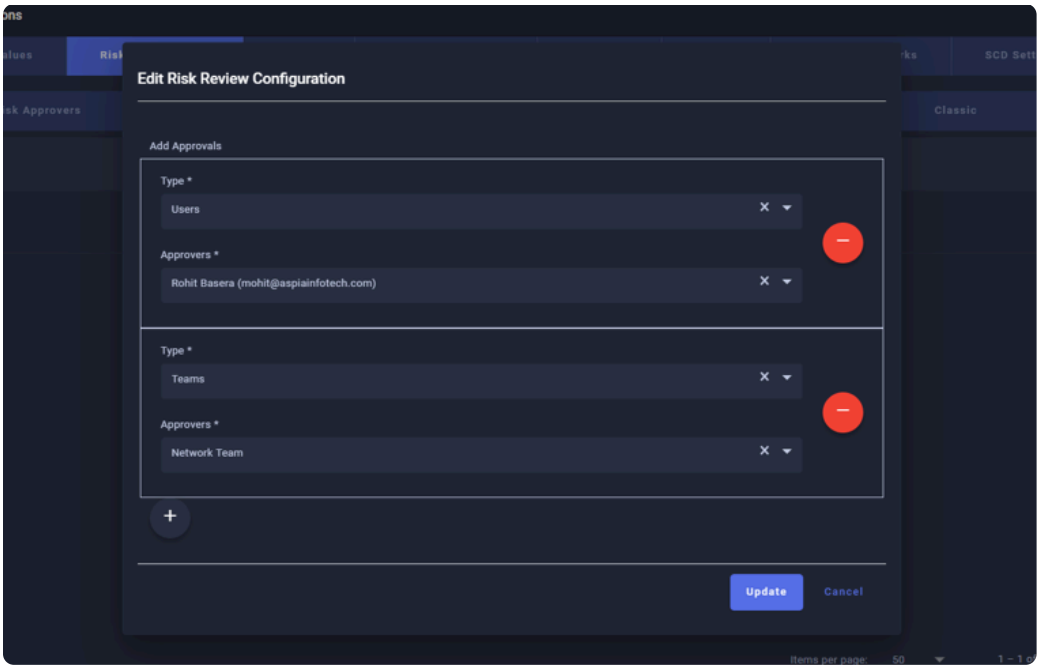
1 - Risk Approvers

- **Navigation**: Go to **GRC Configuration > Risk Configuration > Risk Approvers**. Click on the **Add** button to add risk approvers. You can define multiple levels of approvers based on the requirements.
- **Usage**: Risk Approvers are involved in the **risk acceptance** process. Once a risk is created, it is routed **to the configured approvers, level by level,** for approval.



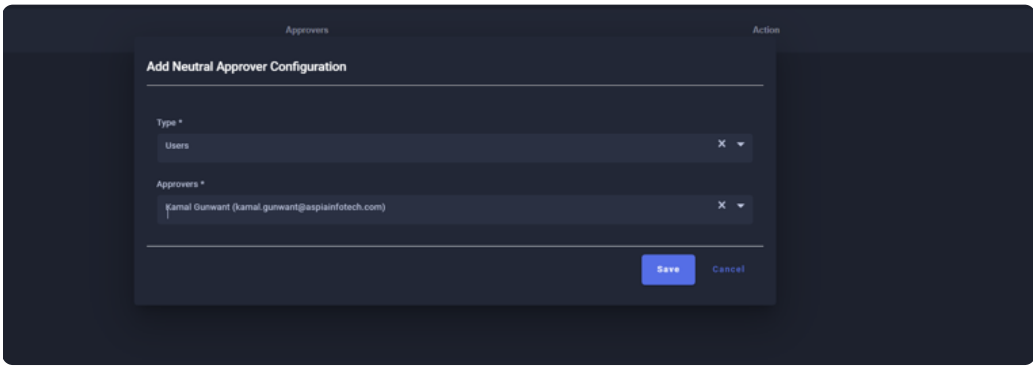
2 - Risk Mitigation Approvers

- **Navigation**: Go to **GRC Configuration > Risk Configuration > Risk Mitigation Approvers**. Click on the **Add** button to define mitigation approvers. Multiple approval levels can be added as needed.
- **Usage**: Risk Mitigation Approvers are used during the **risk mitigation** phase. Once a risk is accepted and partially or fully mitigated, it is routed **to the configured approvers, level by level,** for approval.



3 - Risk Neutral Approver (Optional)

- **Navigation**: Go to **GRC Configuration > Risk Configuration > Neutral Approver Configuration**. Click on the **Add** button to set a neutral approver. Only one neutral approver can be added.
- **Usage**: A Risk Neutral Approver is used when the **risk owner and approver are the same person** at any approval level. In such cases, the approver at that level is replaced by the neutral approver.



Note:

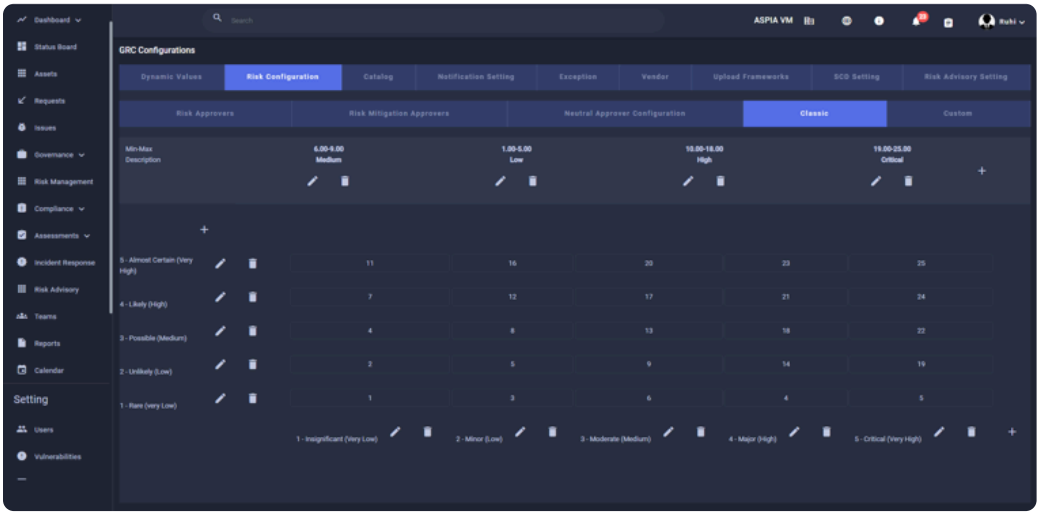
If the Neutral Approver is not configured and the **risk owner and approver are the same person** at any level, that level will be **automatically approved**.

Risk Formula Configurations :-

Usage: Risk Formulas are used to calculate the **Risk Score** based on various input parameters such as Impact, Likelihood, and Detectability. This score helps in categorizing the risk level (e.g., Low, Medium, High, Critical) and drives decision-making for mitigation and approvals.

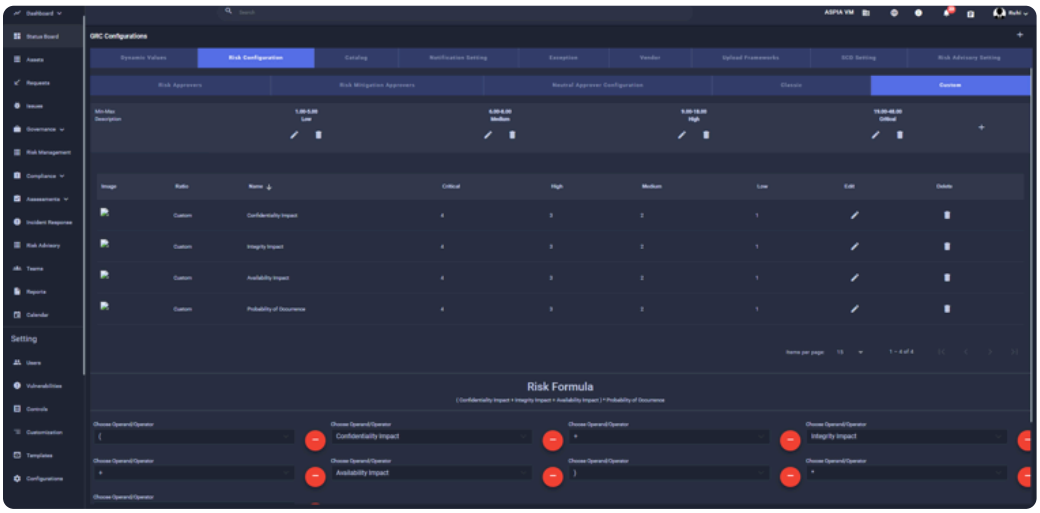
Classic Formula

- The **Classic** formula uses a fixed mathematical equation, typically in the form:
  Risk Score = Impact × Likelihood

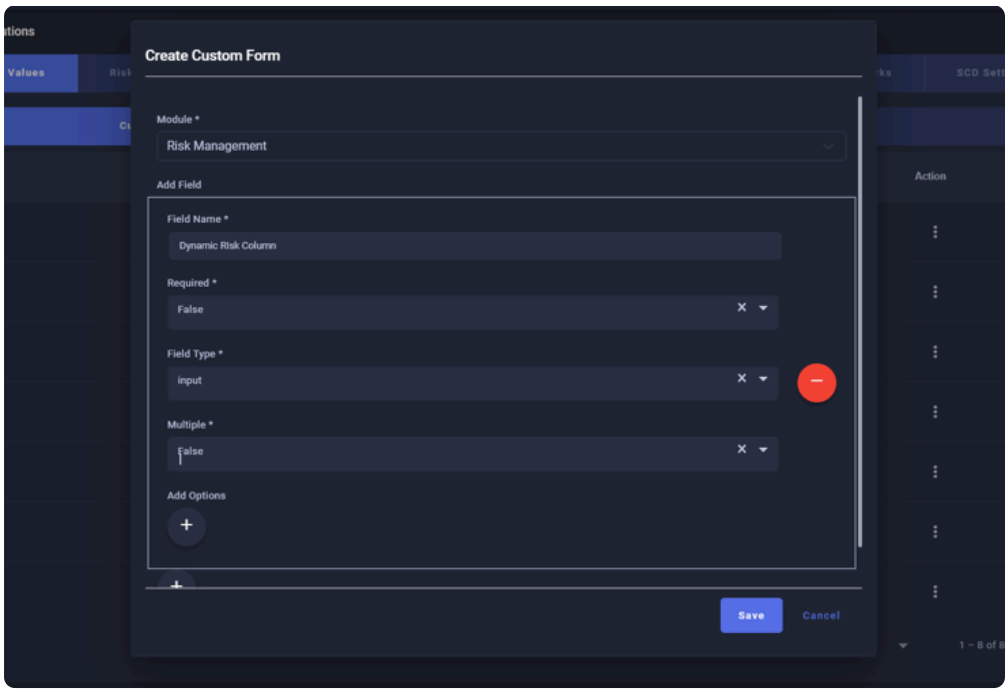


Custom Formula

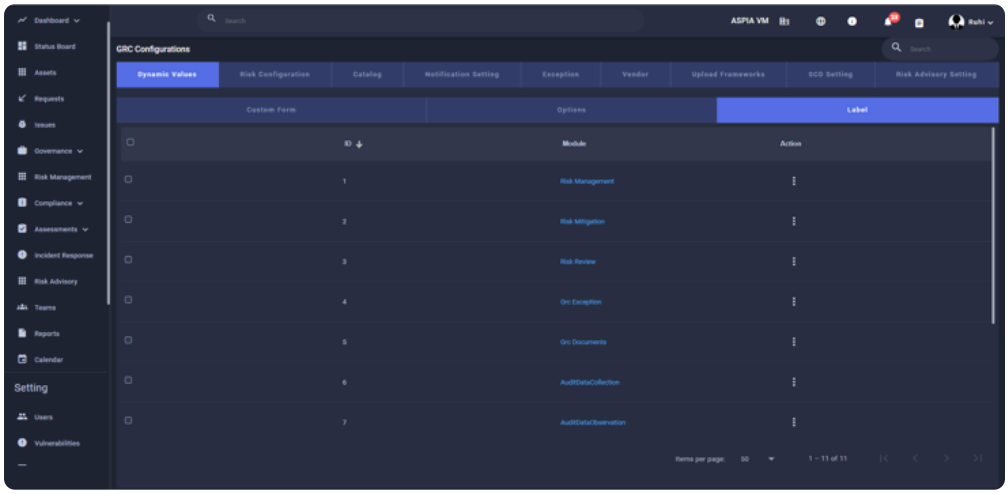
- The **Custom** formula allows organizations to define their own logic using available fields (e.g., Impact, Likelihood, Detectability, or any custom fields).



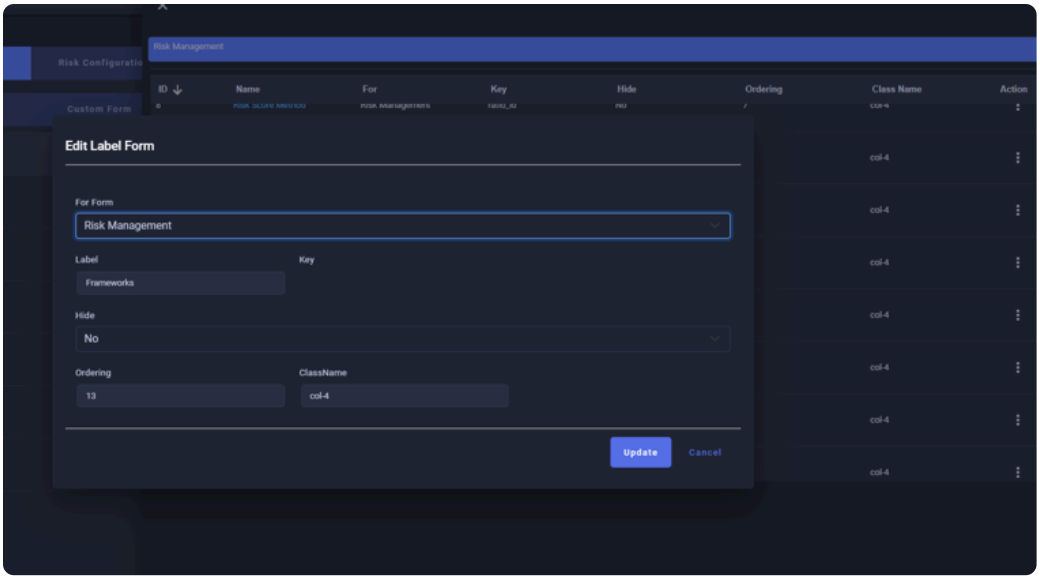
Dynamic Column Configuration

- **Navigation:** Go to GRC Configuration > Dynamic Values > Dynamic Form. Click on the Add button to create dynamic columns.
- **Usage:** Dynamic columns can be created based on organization requirements. If a user needs to add a custom field in the risk form that is not available by default, they can easily create it using this feature.
- 

Label Customization :-

- **Navigation:** Go to GRC Configuration > Dynamic Values > Label. Click on the Risk Management to get all risk labels listing.
- 

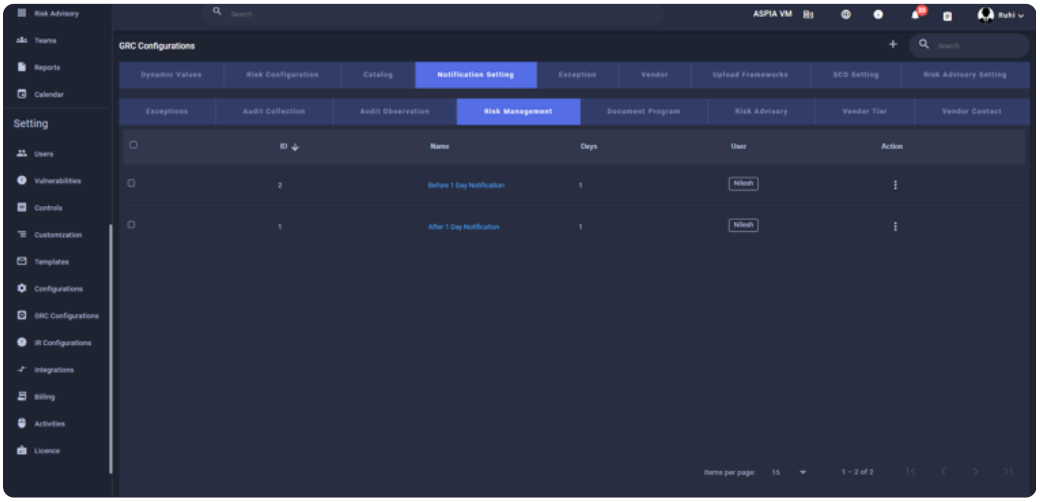
- **Usage**: You can **edit the display names** of columns or **hide specific fields** and also change the ordering and size of the column from the risk form as needed.



Notification Setting :-

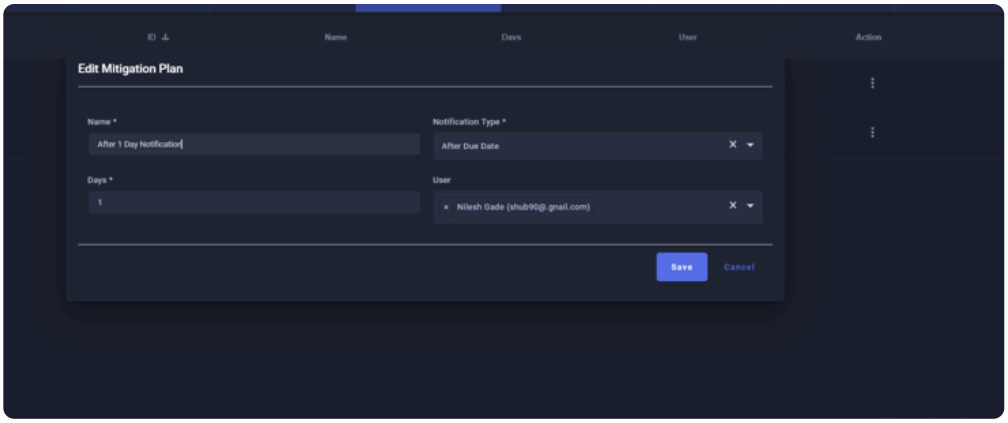
Before Notification Setting

- **Navigation:** Go to GRC Configuration > Notification Setting> Risk Management. Click on the add button to add the notification setting.
- **Usage**: **Before notifications** are sent out based on the **Planned Date** of the risk. You can configure multiple notifications to be triggered at specific intervals **before** the planned date to alert relevant users in advance.



After Notification Setting

- **Navigation:** Go to GRC Configuration > Notification Setting> Risk Management. Click on the add button to add the notification setting.
- **Usage**: "After" notifications are sent **following the Planned Date** of a risk-related event. You can configure **multiple notifications** to be triggered at specific intervals after the planned date to keep relevant users informed and ensure timely follow-ups.



Manager Level Escalation:-

Navigation:

Go to **GRC Configuration > Notification Setting > Risk Management** and select any notification rule (Before or After).

While configuring the notification, you can set the **Manager Levels** value.

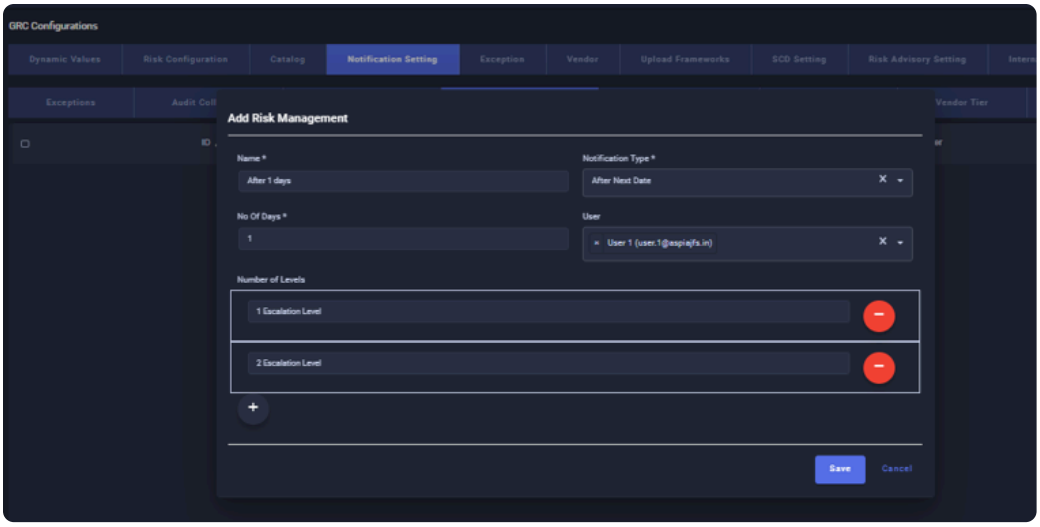
Usage:

Manager Level Escalation enables the system to automatically forward notifications to the supervisory hierarchy above the responsible user. This ensures visibility, accountability, and timely follow-up on risks activities.

Depending on the value set in **Manager Levels**, notifications will be escalated to:

- Level **1** → Sends notification to the user's **direct manager**
- Level **2** → Sends notification to the **manager** and the **manager's manager**
- Level **3+** → Escalates further up the chain, sending notifications to the next-level managers for the specified number of levels

This ensures that not only the responsible user but also their supervisory chain is informed about risks deadlines, breaches, or required follow-ups.

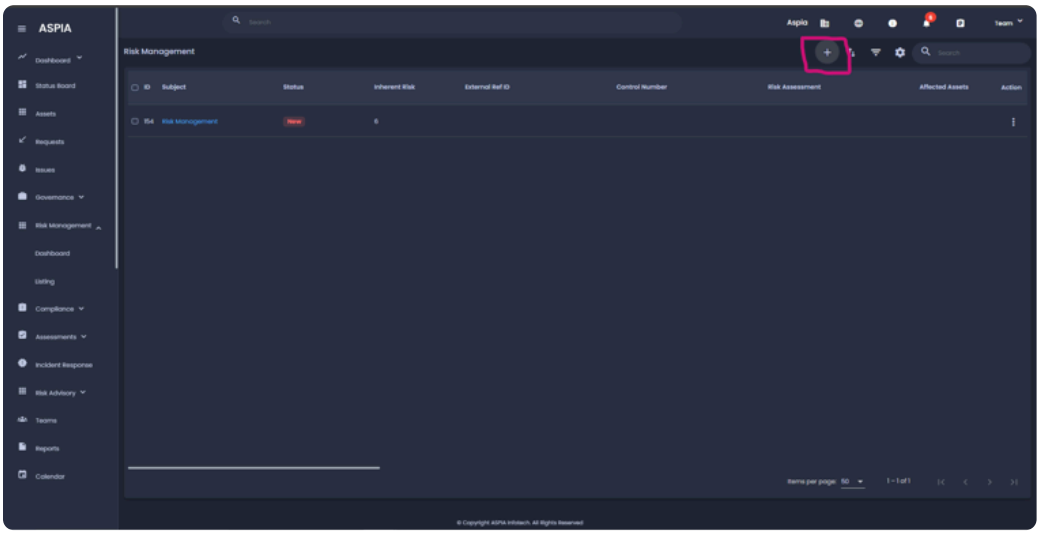


Workflow Overview

Initiator Submits an Risk Request

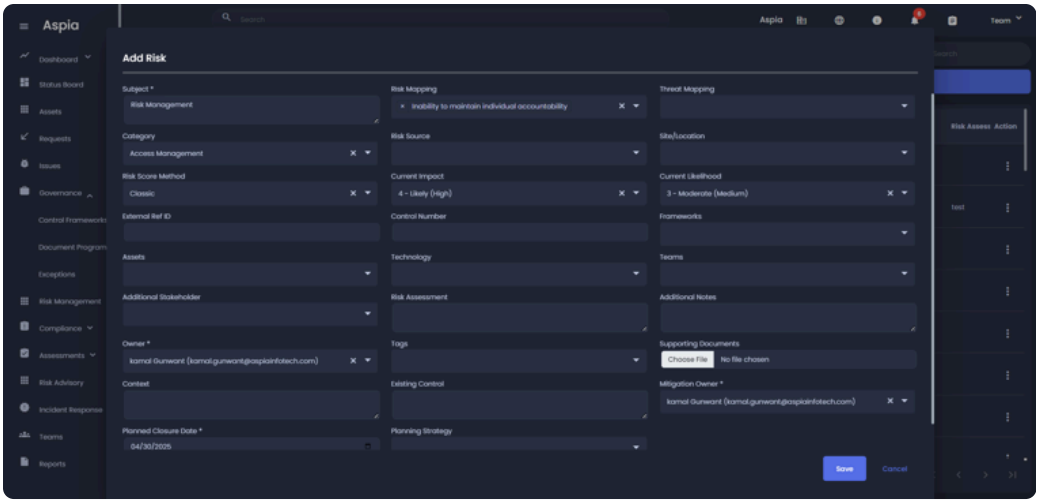
Step 1: Access the ASPIA Platform

- **Action**: Log in to the ASPIA platform using your credentials.
- **Navigation**: Go to the "Risk Management" module from the menu.



Step 2: Initiate a New Risk Request

- **Action**: Click on the “Add Risk" button.
- **Form Completion**:
  - **Subject**: Provide the name of the risk.
  - **Additional Notes**: Provide a detailed description of the risk you are requesting.
  - **Attachments**: Upload any supporting documents if required.



Step 3: Submit the Risk Request

- **Action**: After completing the form, click on the "Save" button.
- **Status**: The request is now in the "New" status.
- **State**: The request is "Inactive" until it is reviewed.
- **Notification**: ASPIA sends an automated email notification to the Risk Owner and the first approver.

Business Head Reviews the Request

Step 1: Receive Notification

- **Action**: first approver (business head) receives an email notification with details of the submitted risk request.

Step 2: Access the Request in ASPIA

- **Action**: Log in to ASPIA and navigate to the "Risk Management" module.
- **Navigation**: Open the risk request.

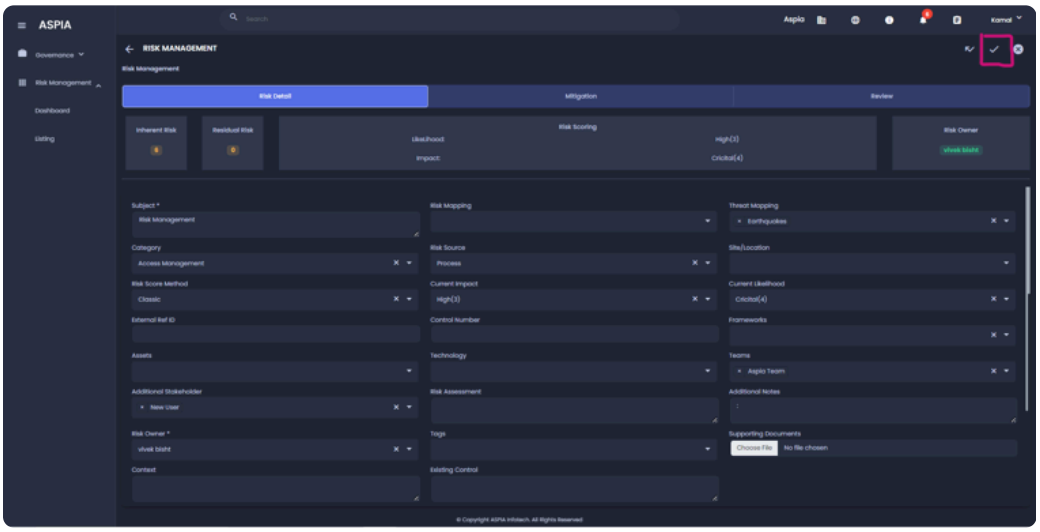
Step 3: Review the Risk Request

- **Action**: Review the details provided by the initiator, including the necessary details and any attached documents.

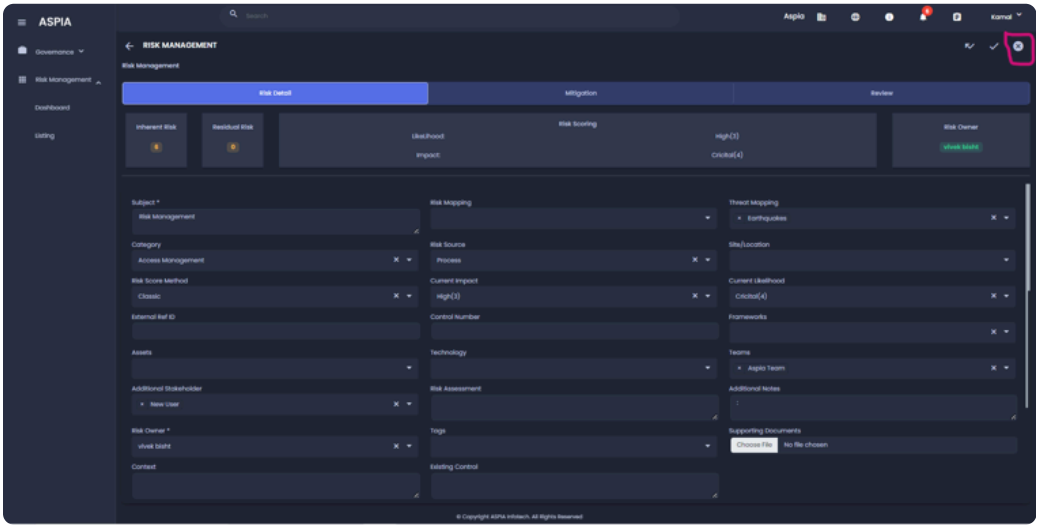
Step 4: Make a Decision

- **Decision Options**:
  - **Approve**:
    - **Action**: Click "Approve" to move the request to the next stage.
    - **Status**: The request status changes to "Review."
    - **State**: The request remains "Inactive."

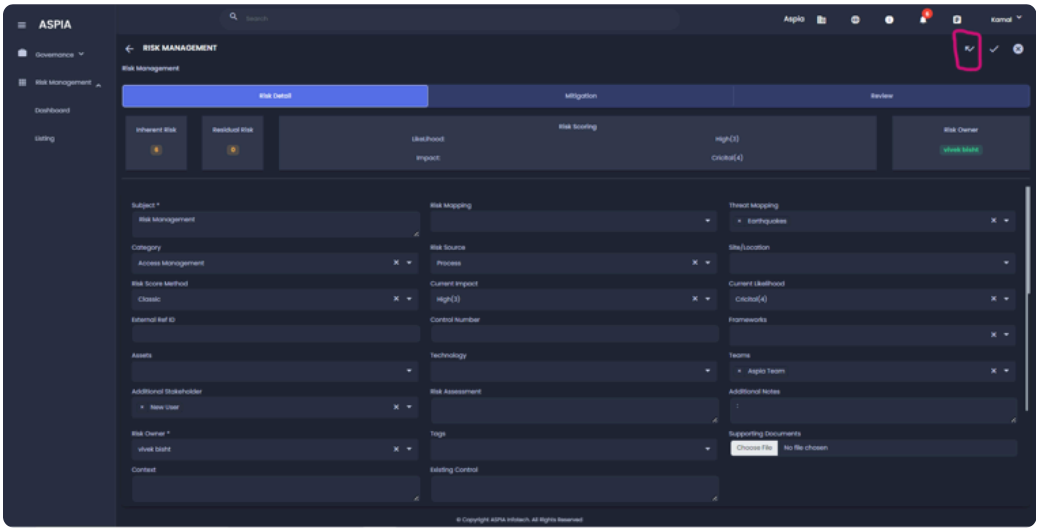
- **Notification**: An email is sent to the Risk Owner and Second Approver(configured from configuration).



- **Reject**:
  - **Action**: Click "Reject" to deny the risk request.
  - **Status**: The request status changes to "Closed."
  - **State**: The request becomes "Inactive."
  - **Notification**: An email is sent to the Risk Owner, informing them of the rejection.



- **Send Back**:
  - **Action**: Click "Send Back" to request additional information from the initiator.
  - **Status**: The request status changes to "Info Required."
  - **State**: The request remains "Inactive."
  - **Notification**: An email is sent to the Risk Owner, requesting further details.



ISG/CISO Reviews the Risk Request

Step 1: Receive Notification

- **Action**: Second Approver(ISG/CISO) receives an email notification for approval.

Step 2: Access the Request in ASPIA

- **Action**: Log in to ASPIA and navigate to the "Risk Management" module.
- **Navigation**: Open the risk request from the "Pending Approvals" section.

Step 3: Review the risk Request

- **Action**: Review the comments and any additional information provided by the initiator or first approver.

Step 4: Make a Decision

- **Decision Options**:
  - **Approve**:
    - **Action**: Click "Approve" to move the request to the final approver.
    - **Status:** The request status changes to "Monitor."
    - **State**: The request becomes "Active."
    - **Notification**: An email is sent to the Risk Owner, informing them that the risk has been approved.
  - **Reject**:
    - **Action**: Click "Reject" to deny the risk request.
    - **Status**: The request status changes to "Closed."
    - **State**: The request becomes "Inactive."
    - **Notification**: An email is sent to the Risk Owner, informing them of the rejection.

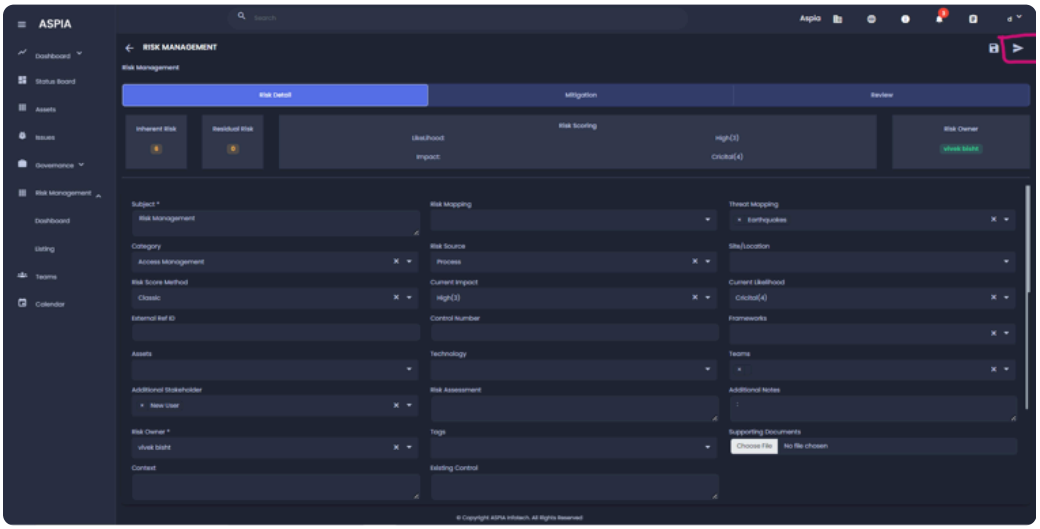
- **Send Back**:
  - **Action**: Click "Send Back" to request additional information from the initiator.
  - **Status**: The request status changes to "Info Required."
  - **State**: The request remains "Inactive."
  - **Notification**: An email is sent to the Risk Owner, requesting further details.

Send Back Process

- If a risk is send back at any stage of the approval workflow, it **sent back** to the **Risk Owner** for modifications.
- The **approver** will specify the reason for sending the risk back (e.g., missing information, inadequate mitigation plan).

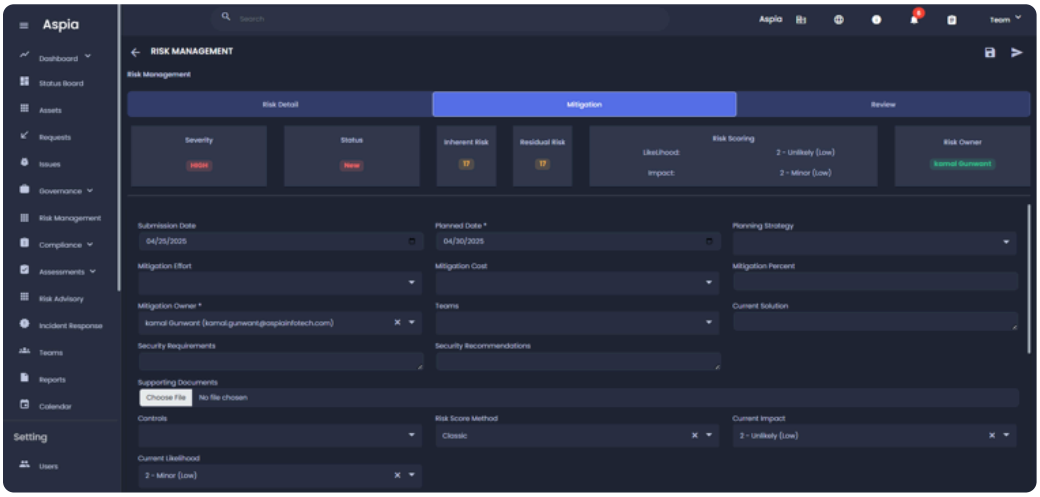
Risk Owner Modifications

- Once the risk is sent back, the **Risk Owner** is notified and must take the following actions:
  - Review the feedback provided by the approver.
  - Make the necessary modifications to the risk, such as:
    - Updating risk details (e.g., subject, description).
    - Revising the mitigation plan.
    - Addressing any concerns raised by the approver.
- After making the modifications, the Risk Owner will re-submit the risk for approval by selecting the **Submit for Re-Approval** option.



Adding Mitigation Details

- **Once the risk is fully approved**, the **Risk Owner** is responsible for adding the necessary details in the **Mitigation Section**:
  - **Mitigation Owner**: Assign the individual responsible for implementing the mitigation actions.
  - **Mitigation Approver**: Specify the approver who will review and approve the mitigation plan once it is completed.
  - **Planned Mitigation Date**: Enter the expected completion date for the mitigation plan.
  - Any other relevant mitigation details must be added to ensure the risk is adequately managed.

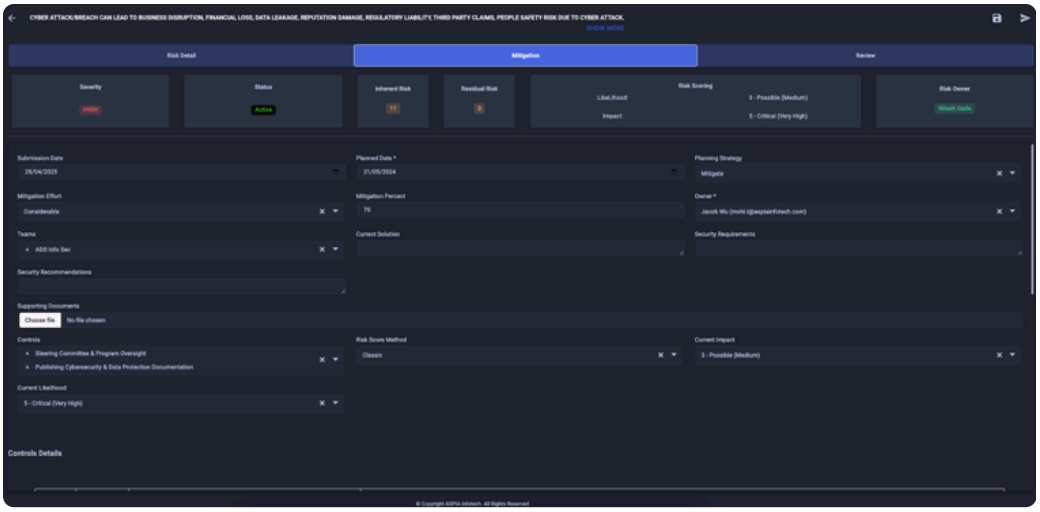


Submit the Risk Mitigation

- **Action**: After completing the form, click on the "Save" button.
- **Notification**: ASPIA sends an automated email notification to the Risk Mitigation Owner and Risk Mitigation Approver.

Mitigation Process

1. **Mitigation by Mitigation Owner:**
   - The **Mitigation Owner** is responsible for carrying out the mitigation actions. Once the mitigation actions are complete, the Mitigation Owner fills out the **Likelihood** and **Impact** fields related to the risk.
   - After completing these details, the Mitigation Owner submits the mitigation for approval.
2. **Send for Approval:**
   - Once submitted, an email notification is sent to the **Mitigation Approver** for review and approval.

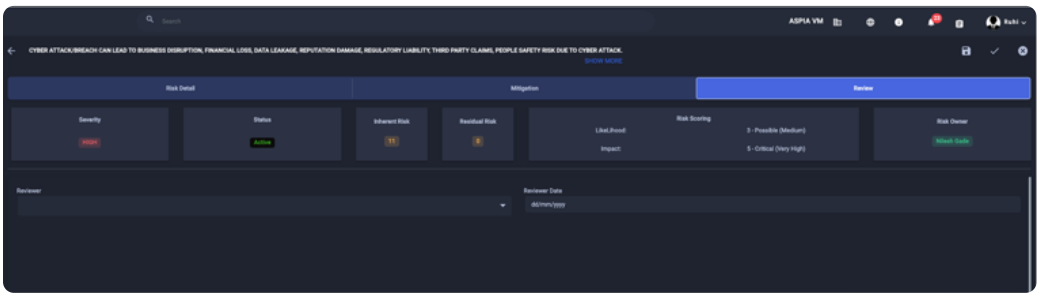


Decision Options for Mitigation Approver

1. If Mitigation Percentage is Less than 100%:

Send For the Approval only to the first mitigation approver

- **Approved by Mitigation Approver**:
  - **Action**: Click "Approve".
  - **Residual Risk** : Residual risk will be calculated as per the configured risk formula and displayed on the screen.
  - **Notification**: An email is sent to the Risk Mitigation Owner
- **Rejected by Mitigation Approver**:
  - **Action**: Click "Reject" .
  - **Residual Risk** : Residual risk will not be recalculated and will remain the same as earlier.
  - **Notification**: An email is sent to the Risk Mitigation Owner



2. If Mitigation Percentage is 100%:

Send for the Approval to all all the mitigation approvers level by level

Approval Process:

- **Step 1: Approval by Mitigation Approver**
  - Once the mitigation percentage reaches 100%, the mitigation is sent to the Mitigation Approver for review.
  - The Mitigation Approver reviews the provided mitigation and can either approve or reject it.

  Approve by Mitigation Approver:

  - **Action:**
    - Click **Approve** to approve the mitigation plan.
  - **Next Step:**
    - Once approved, the mitigation plan is sent to the another approver (if is there) for further review and approval.

  Reject by Mitigation Approver:

  - **Action:**
    - Click **Reject** if the mitigation plan requires further modifications.
  - **Residual Risk:**
    - If rejected, the **Residual Risk** will **not be calculated**.
  - **Notification:**
    - An email is sent to the **Risk Mitigation Owner**, informing them that the mitigation was rejected.

Step 2: Approval by Final Mitigation Approver

- Once the Mitigation Approver has approved the 100% mitigation, it goes to the Final Approver/CISO for final approval.

  Approve by Final Approver:

  - **Action:**
    - Click **Approve** to give final approval for the mitigation plan.
  - **Residual Risk:**
    - The **Residual Risk** is automatically calculated and Residual Risk score will become zero.
  - **Notification:**
    - An email is sent to the **Risk Mitigation Owner**, notifying them that the risk has been fully mitigated and closed.
  - Risk Status : Closed

  Reject by Final Approver:

  - **Action:**

        - Click **Reject** if the mitigation plan is unsatisfactory.
    - **Residual Risk:**
        - If rejected, the **Residual Risk** will **not be calculated**.
    - **Notification:**
        - An email is sent to the **Risk Mitigation Owner**, informing them of the rejection.

Change Approver

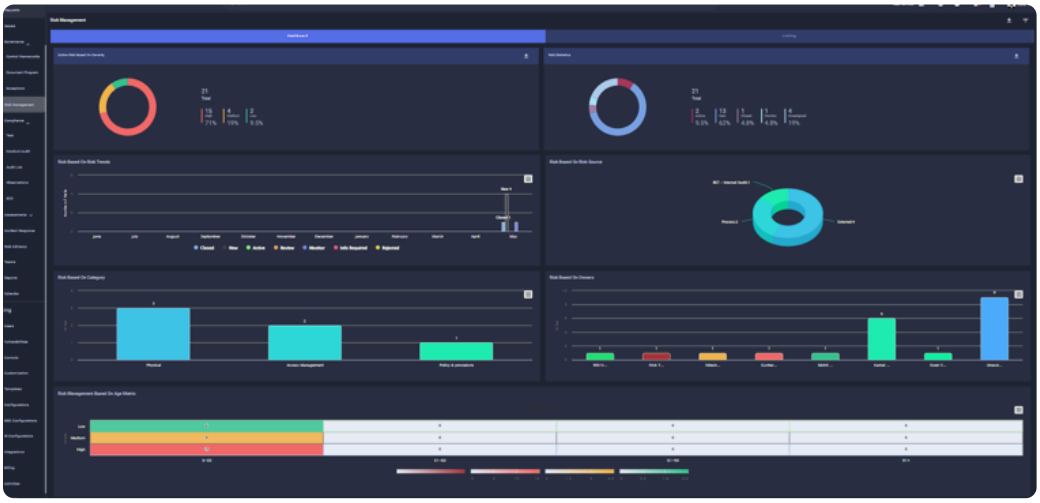
Privileged User Action

- **Action**: A user with higher privileges can change the approvers if any approver is unavailable if risk not approved till now.

Dashboard For Risk Management

Navigation: Go to **Risk Management > Dashboard** to view comprehensive visual insights related to Risk Management.

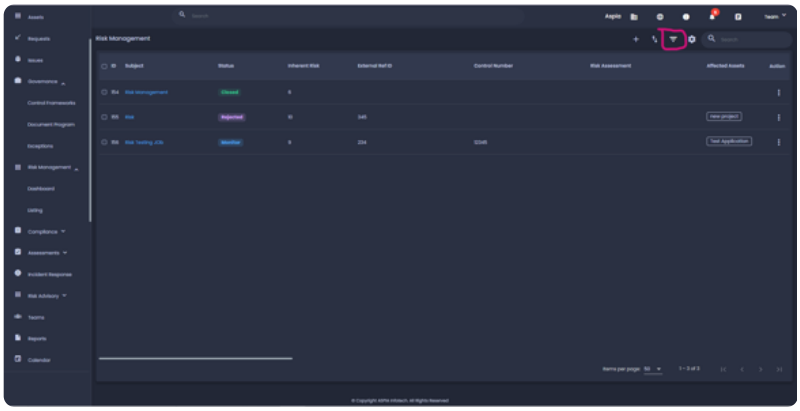
Usage:
The Central Dashboard is a comprehensive, real-time interface that provides actionable visual insights into your organization's risk landscape. Designed for clarity and efficiency, it consolidates risk-related data from across the system into a unified view, enabling faster analysis and informed decision-making.



Filters in the Risk Management Module

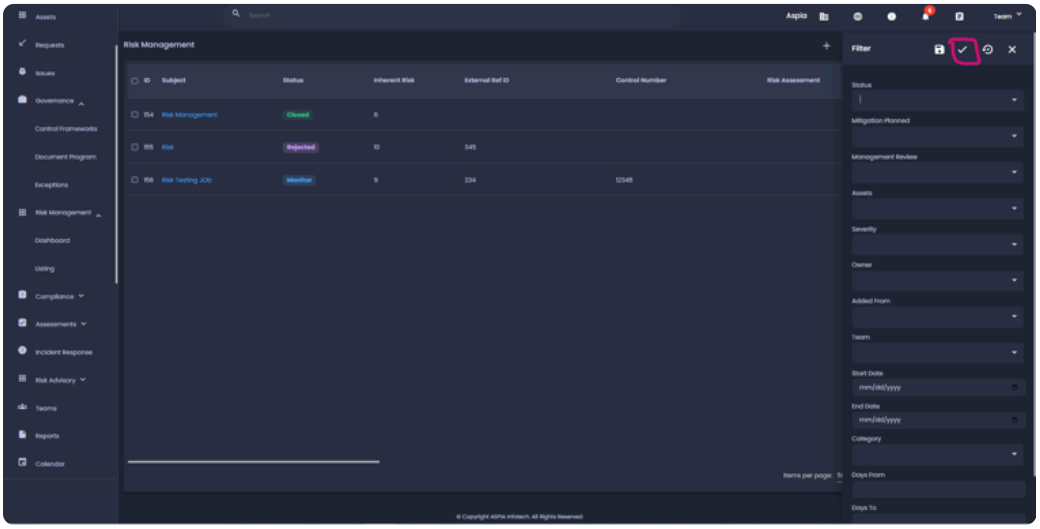
Access the Risk Management Dashboard

On the right-hand side of the screen, you'll see a filter panel with multiple dropdowns and date selection fields. Click on the filter icon

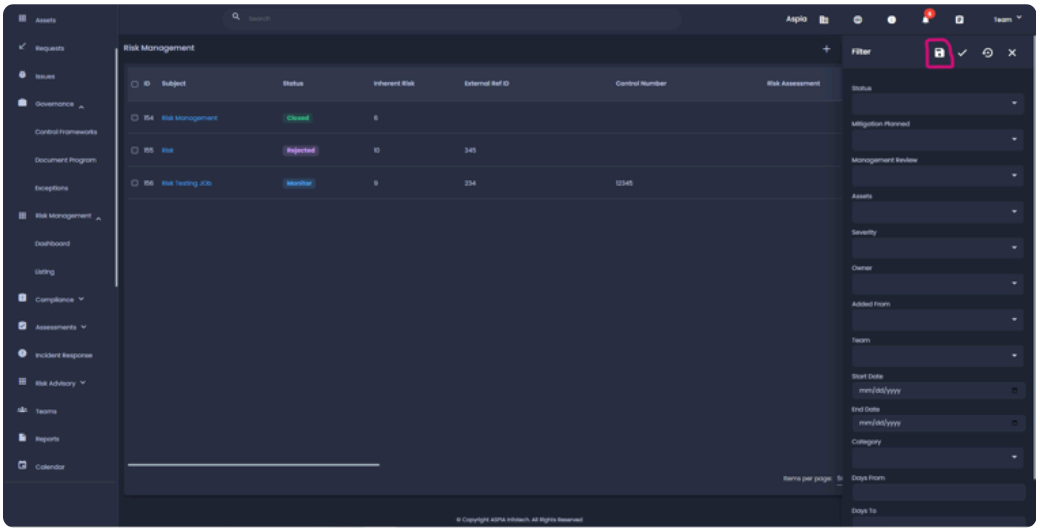


Apply and Save Filters:

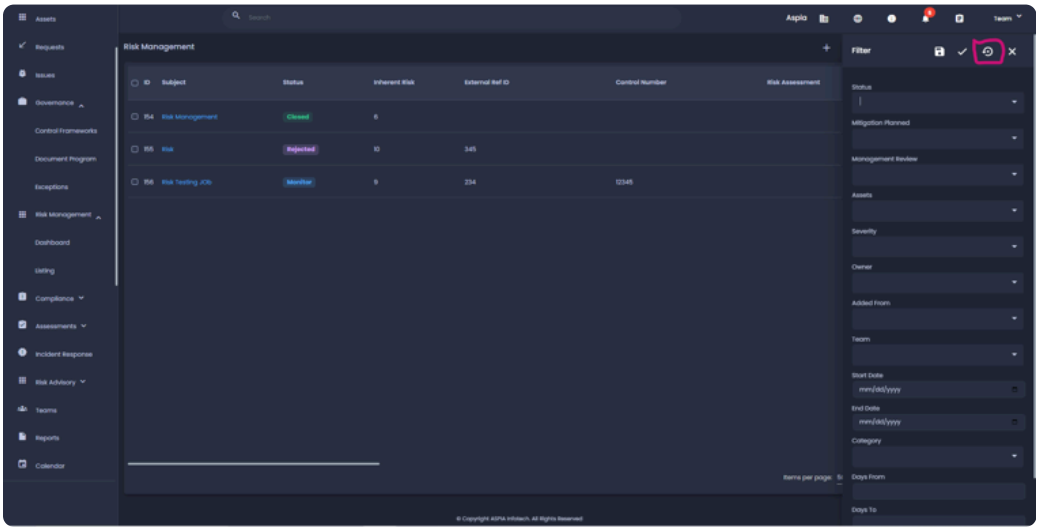
Once you've selected the desired criteria, click the "Apply" button to update the list of risks shown on the dashboard based on the applied filters.



To save the filter configuration for future use, click on the Save icon . This will allow you to name and store the filter settings, making it easy to reuse them later.

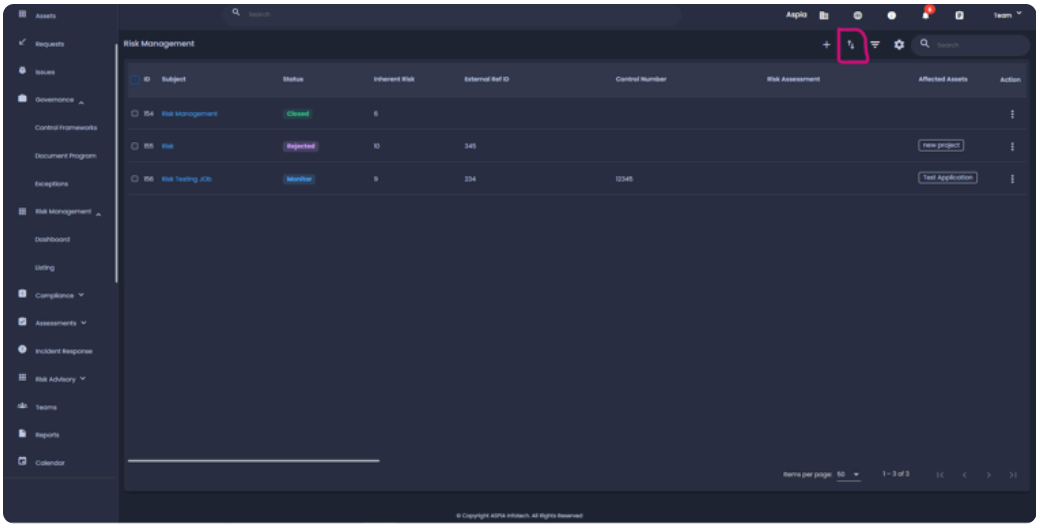


If you want to reset the filters and see all risks again, click the reset button then save changes



Import Data

- **Step 1**: Go to the Risk Management section and locate the **Import** button at the top of the risk listing page.
- **Step 2**: Click the **Import** button to upload a file containing the risk data you want to import. Accepted formats are typically `.xlsx`.
- **Step 3**: A file selection dialog will appear; choose your file and upload it.

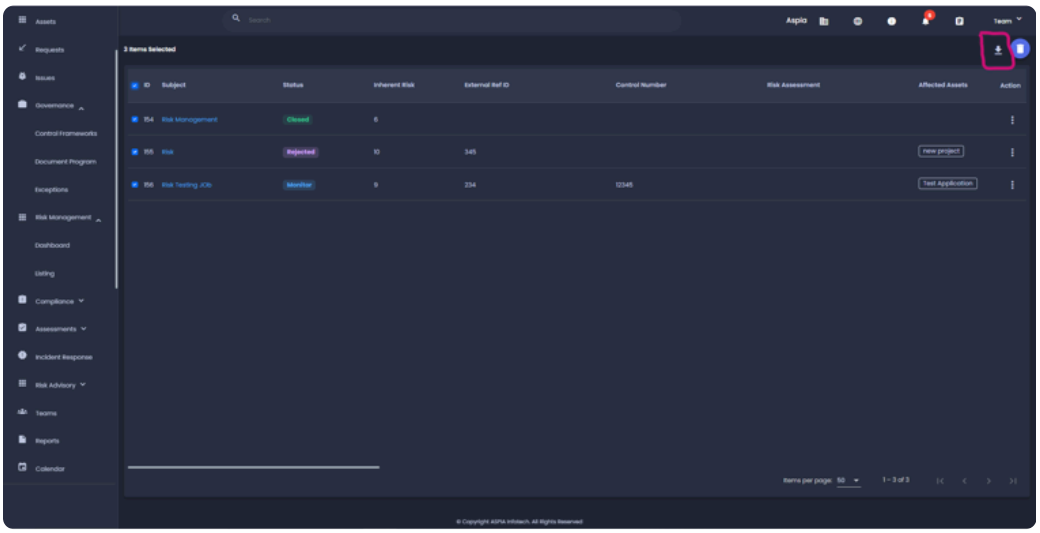


Important Notes:

- Ensure that your file follows the required format (e.g., column headers match system fields).
- Review the data for any inconsistencies before uploading

Export Data

- **Step 1**: To export risk data, select the risk's
- **Step 2**: Click the Export button to download the current list of risks or filtered risks.
- **Step 3**: The system will generate the file, and it will be automatically downloaded to your device.



Automated Email Notifications

Step 1: Due Date Reminder

- **Action**: As the risk's due date approaches, ASPIA triggers an automated email reminder to the Risk Owner.
- **Purpose**: To ensure that the Risk Owner is aware of the upcoming deadline and can take necessary actions if needed.

Activity Tracking

Step 1: Access the Risk's Activity Log

- **Action**: To view the history of actions taken on a specific risk request, log in to the ASPIA platform.
- **Navigation**: Go to the "Risk Management" module and select the relevant risk request.
- **Accessing the Log**: Click on the "Activity" tab within the risk request to view the log.
- **Details Available**: The activity log will show a chronological record of all changes, including submissions, approvals, rejections, and any modifications made to the request.

Step 2: Review the Detailed Activities

- **Action**: In the activity log, users can see detailed information about each action taken, such as:
  - **Timestamp**: When the action was performed.
  - **User**: Who performed the action.
  - **Action Description**: What specific action was taken (e.g., "Risk Approval Date has been modified," "Risk Status has been modified,").
- **Purpose**: This log allows users to track the progress of the risk request and provides transparency in the decision-making process.

Record Keeping

All risk requests and their corresponding actions, decisions, and notifications will be logged within the ASPIA platform for auditing and review purposes.